

Chương 6. Triển khai nhận dạng dựa trên PKI với Blockchain

Mục tiêu bài học

- Hiểu được cơ sở hạ tầng khóa công khai
- Hiểu được những thách thức của mô hình PKI hiện có
- Hiểu được những lợi ích của công nghệ Blockchain với hạ tầng PKI

Nội dung bài học

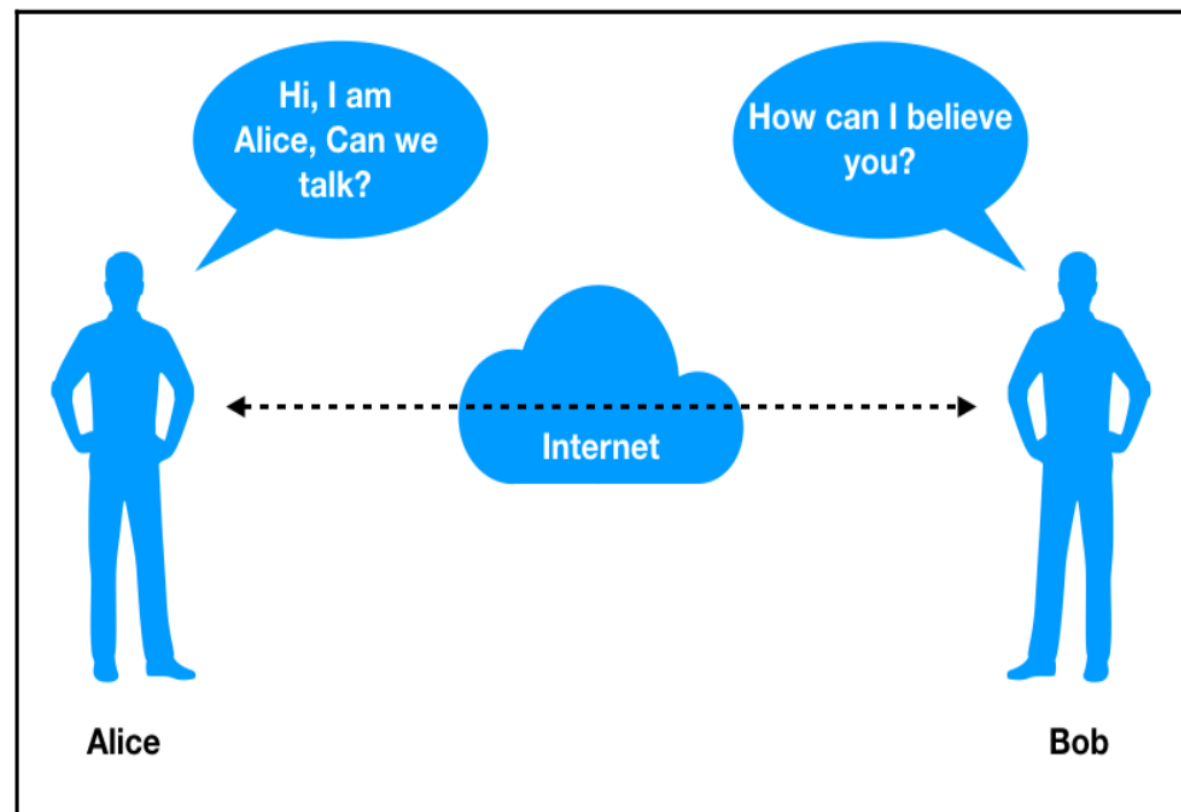
- Cơ sở hạ tầng khóa công khai
- Những thách thức của mô hình PKI hiện có
- Lợi ích của công nghệ Blockchain với hạ tầng PKI

1. Cơ sở hạ tầng khóa công khai

- Người dùng có xu hướng bị mất thông tin cá nhân và bí mật của họ trên không gian mạng Internet và các ứng dụng web lớn.
- PKI cung cấp một phương tiện an toàn để xác thực định danh của một cá nhân, giúp các doanh nghiệp có thể giảm thiểu rủi ro trong việc triển khai và quản lý các ứng dụng.
- Các doanh nghiệp đang hướng đến các ứng dụng dựa trên cloud nhiều hơn. Vì vậy cần phải bảo vệ các ứng dụng nhạy cảm khỏi các mối đe dọa mới.
- Có nhiều mối đe dọa bảo mật khi giao tiếp trực tuyến như đánh cắp định danh, tấn công người ở giữa (MITM) và rò rỉ dữ liệu.

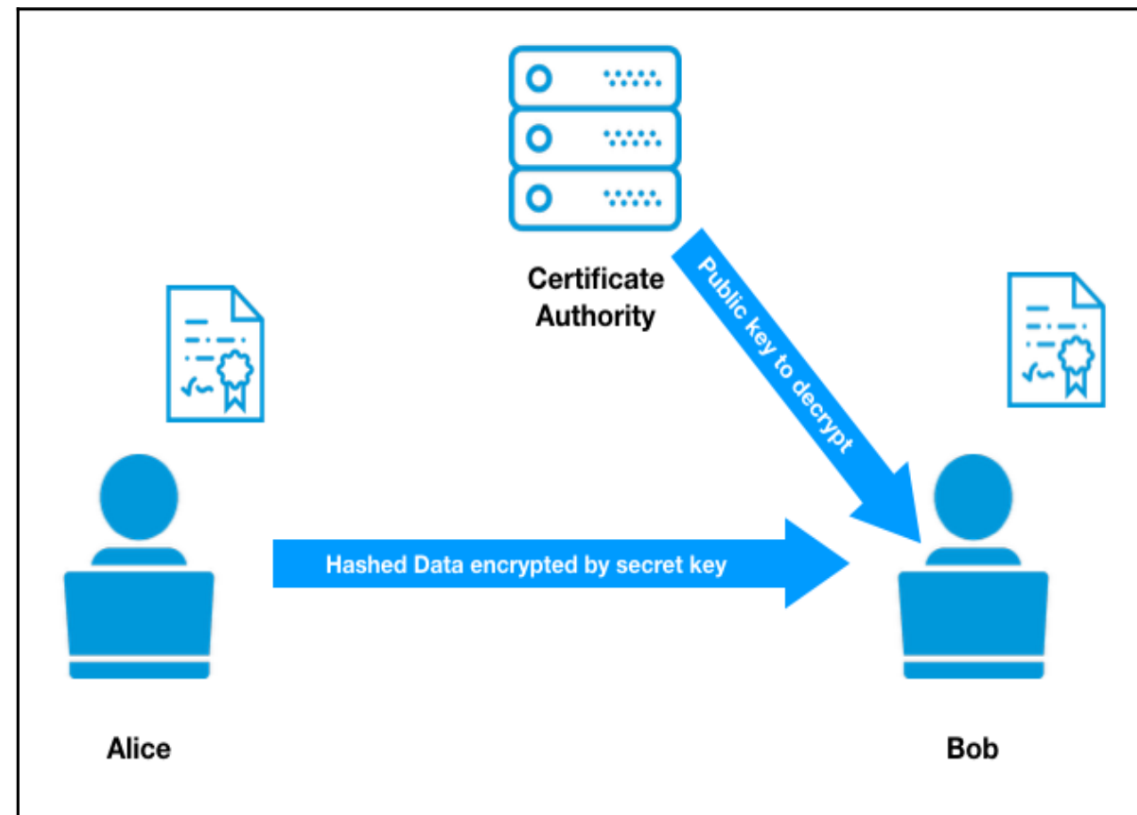
1.1. Tổng quan PKI

- Internet cho phép người dùng kết nối với với nhau, không còn rào cản địa lý, do đó, sẽ rất khó để xác định một người qua Internet và thiết lập sự tin cậy trong truyền thông.
- Trong sơ đồ sau đây, Alice muốn nói chuyện với Bob qua Internet; tuy nhiên, Bob từ chối vì anh không có bất kỳ phương tiện nào để xác minh danh của Alice:



1.1. Tổng quan PKI

- PKI giải quyết vấn đề này bằng cách sử dụng thêm một bên thứ ba đáng tin cậy (TTP) giữa Bob và Alice.
- Trước khi họ có thể bắt đầu làm quen với nhau, họ phải thiết lập sự tin cậy và TTP giúp thực hiện điều đó.
- Trong sơ đồ sau đây, Alice chia sẻ chứng chỉ số với Bob và Bob sử dụng khóa công khai từ tổ chức cấp chứng chỉ tin cậy để giải mã chữ ký này và xác thực Alice:

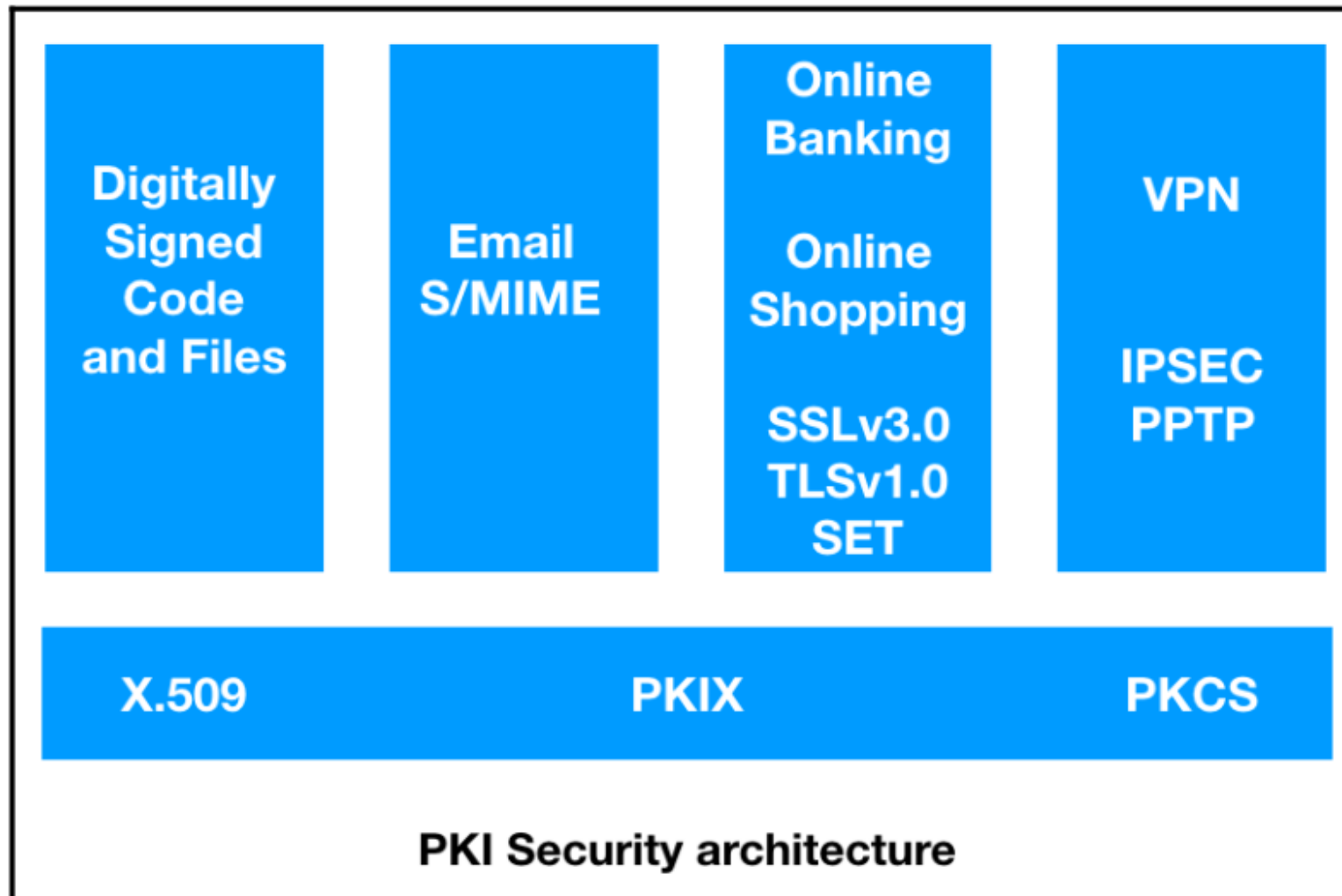


1.1. Tổng quan PKI

Trong sơ đồ trước, TTP là tổ chức cấp giấy chứng nhận (CA) được dùng để tạo ra một chứng chỉ giúp người dùng Internet hiển thị định danh của mình qua Internet:

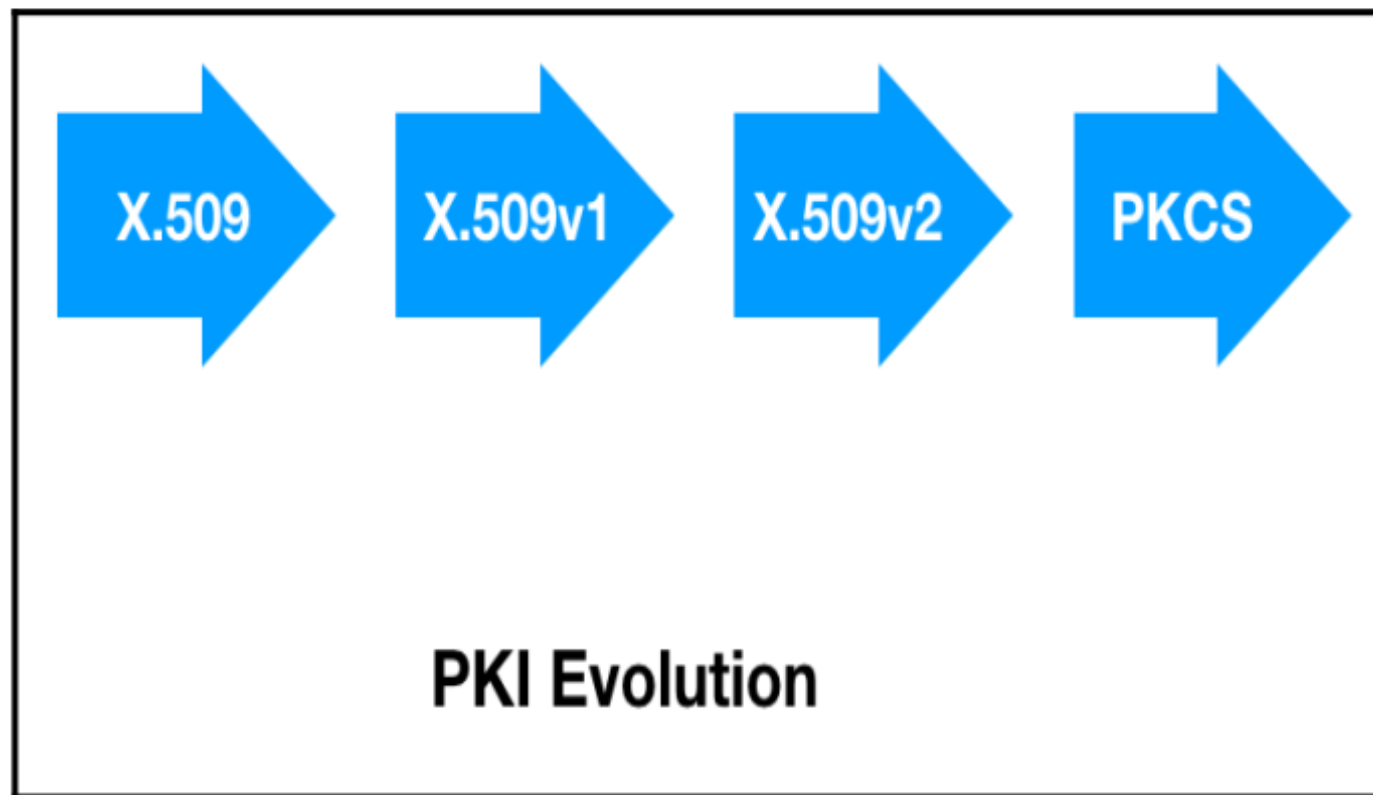
- **PKI:** cung cấp tiêu chuẩn phân cấp để quản lý tài sản kỹ thuật số của một thực thể để thiết lập kênh liên lạc an toàn. Nó không chỉ giới hạn ở người dùng mà còn được sử dụng bởi một số hệ thống khác như email, ứng dụng web, thẻ thông minh...
- **Thiết bị mạng:** PKI được sử dụng để kiểm soát quyền truy cập vào bộ định tuyến và thiết bị chuyển mạch với cơ chế xác thực 802.1X. Ví dụ: chứng thực Wifi qua Radius.
- **Ứng dụng:** các ứng dụng cần phải có được 1 certificate đã lưu ký bởi CA để chạy trong hệ điều hành.
- **Đường hầm IPsec:** Bộ định tuyến và tường lửa sử dụng chứng chỉ để xác thực các thiết bị đầu cuối khác qua Internet.
- **Máy chủ Radius:** truy vấn Lightweight Directory Access Protocol (LDAP) được bảo vệ bằng chứng chỉ PKI.

1.1. Tổng quan PKI

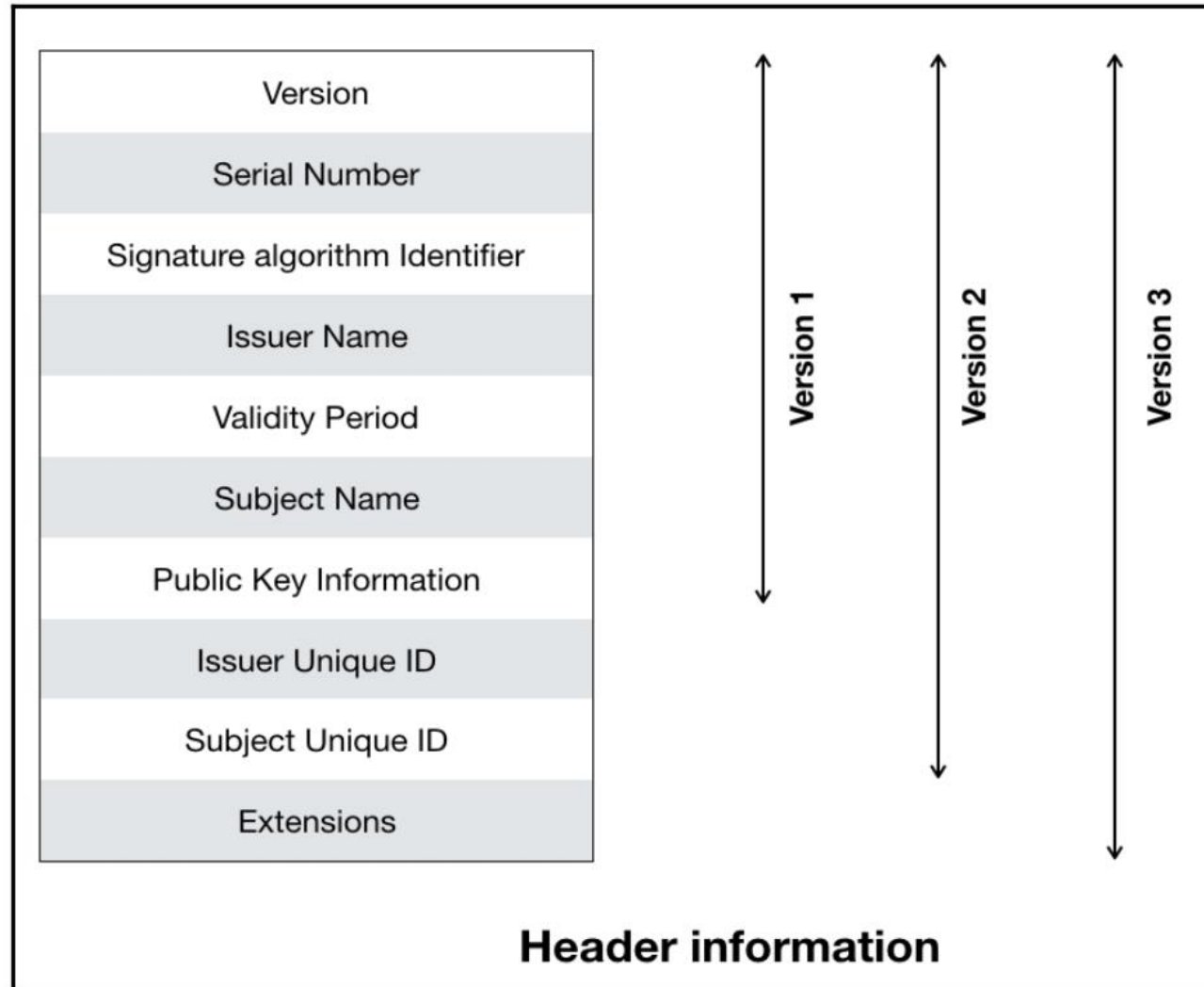


1.2. Sự phát triển của PKI

- Thiết kế X.509 xây dựng định dạng dữ liệu và thủ tục cho việc lưu trữ và phân phối các khóa công cộng thông qua chứng chỉ được ký điện tử bởi CA.
- Tuy nhiên, X.509 không bao gồm một hồ sơ để xác định hỗ trợ nhiều trường con của chứng chỉ và phần mở rộng, hiển thị như sau:



1.2. Sự phát triển của PKI

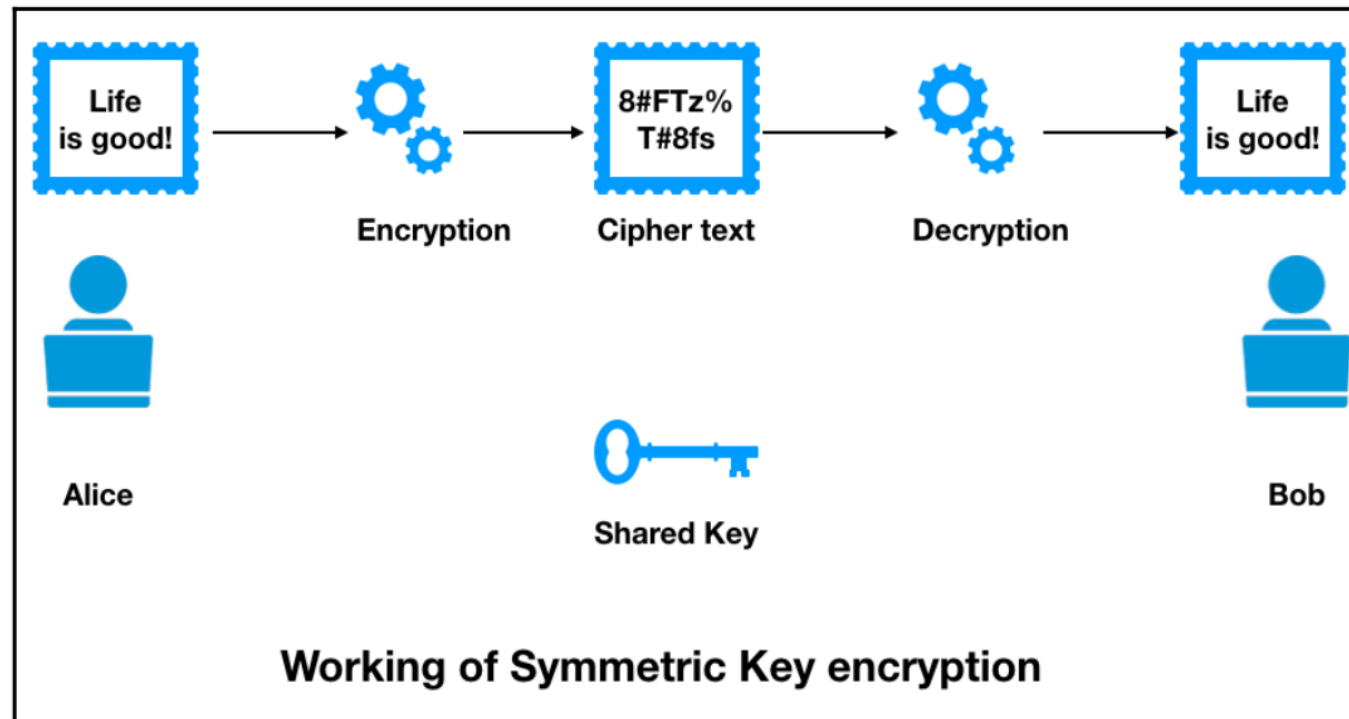


1.3. Các thành phần

- PKI là một tập hợp của một loạt các thành phần, ứng dụng, chính sách, và thực tiễn nhằm kết hợp và thực hiện ba nguyên tắc bảo mật, đó là tính toàn vẹn (Integrity), xác thực (Authentication), và không thể từ chối (Non-repudiation).
- Chứng chỉ kỹ thuật số là các thành phần chính trong PKI khi chúng hoạt động như một định danh kỹ thuật số trên Internet.

1.4. Mã hóa khóa bất đối xứng

- **Mã hóa đối xứng:** Trong mã hóa đối xứng, cùng một khóa được sử dụng để mã hóa và giải mã dữ liệu. Điều này là cần thiết để đảm bảo rằng cả hai bên sử dụng cùng một khóa để mã hóa và giải mã dữ liệu.

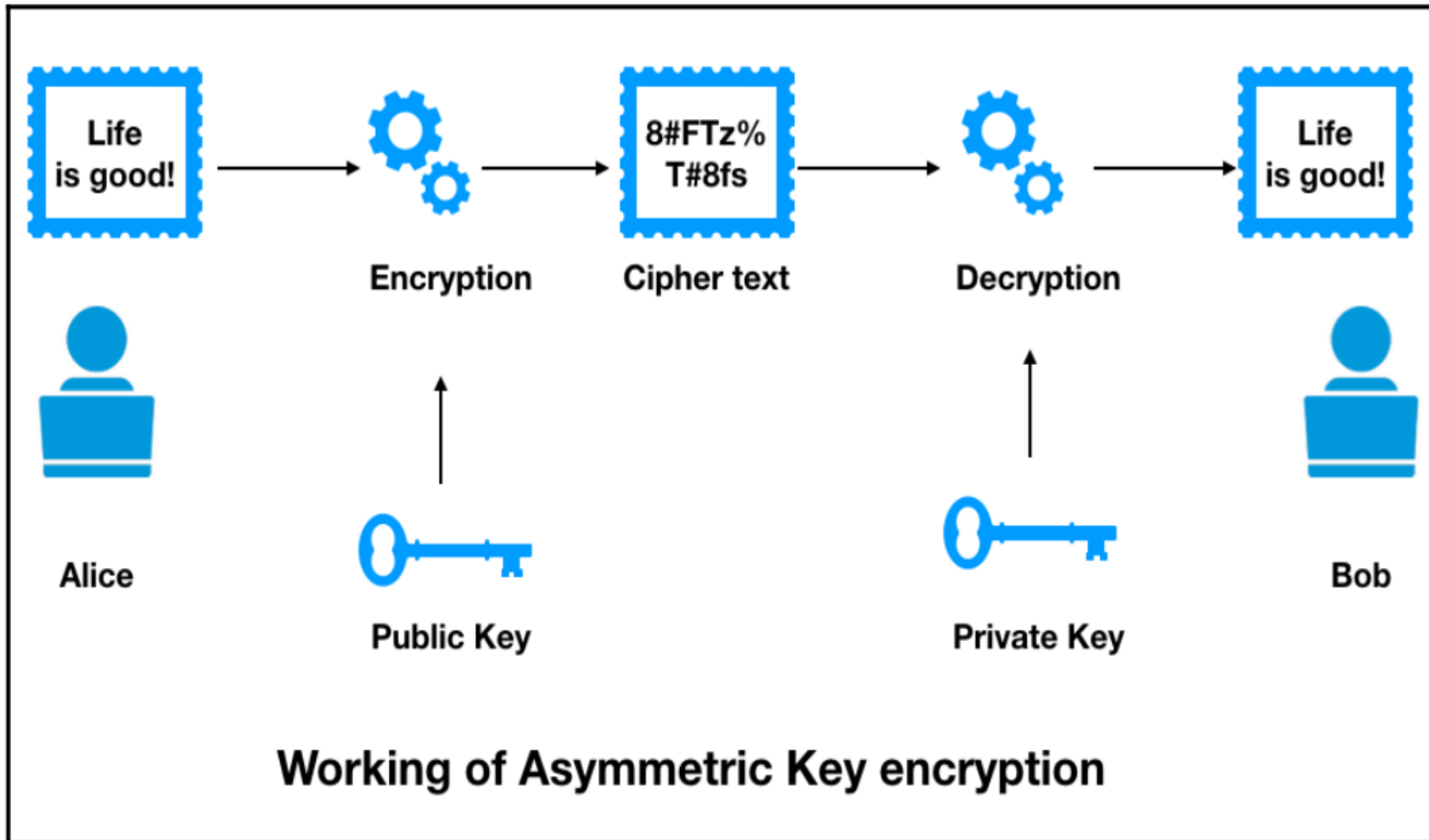


1.4. Mã hóa khóa bất đối xứng

- **Mã hóa bất đối xứng:**

- Một cặp khóa được sử dụng để mã hóa và giải mã dữ liệu. Cặp khóa này là sự kết hợp của khóa công khai và khóa riêng.
- Khóa công khai được sử dụng để mã hóa dữ liệu, trong khi khóa riêng được sử dụng để giải mã dữ liệu.
- Khóa công khai được cung cấp cho tất cả mọi người thông qua Internet và được lưu trữ trong một kho lưu trữ hoặc thư mục có thể truy cập. Khóa riêng phải được giữ riêng cho chủ sở hữu nên nó còn được gọi là khóa bí mật.
- Dữ liệu được mã hóa bằng khóa công khai chỉ có thể được giải mã bằng khóa bí mật tương ứng vì chúng được kết nối với nhau về mặt toán học.

1.4. Mã hóa khóa bất đối xứng



1.5. Chứng chỉ (Certificate)

- Chứng chỉ là ID điện tử đại diện cho định danh của người dùng hoặc thiết bị liên quan đến việc giao tiếp qua mạng, đảm bảo rằng chỉ có người dùng hợp lệ mới có thể kết nối với mạng.
- Chứng chỉ được tạo ra bằng cách lưu ký khóa công khai bởi bên thứ ba đáng tin cậy, ví dụ như CA.
- Tiếp theo, chúng ta sẽ tìm hiểu về các chứng chỉ thông dụng.

1.5. Chứng chỉ (Certificate)

Chứng chỉ Lớp Công Bảo mật SSL (Server certificate):

- Được cài đặt trên các dịch vụ lưu trữ máy chủ, như ứng dụng web, máy chủ thư điện tử, thư mục hoặc máy chủ LDAP, chứa thông tin nhận dạng về tổ chức sở hữu ứng dụng và khóa công khai hệ thống.
- Chứng chỉ này phải được lưu ký bởi một tổ chức cung cấp chứng chỉ đáng tin cậy. Tên máy chủ chính được liệt kê là tên thông dụng (common name) trong trường chủ đề của chứng chỉ.

Certificate Viewer: www.globalsign.com

General

Details

Issued To

Common Name (CN)

www.globalsign.com

Organization (O)

GMO GlobalSign, Inc.

Organizational Unit (OU)

<Not Part Of Certificate>

Issued By

Common Name (CN)

GlobalSign Extended Validation CA - SHA256 - G3

Organization (O)

GlobalSign nv-sa

Organizational Unit (OU)

<Not Part Of Certificate>

Validity Period

Issued On

Monday, September 26, 2022 at 6:36:05 PM

Expires On

Saturday, October 28, 2023 at 6:36:04 PM

Fingerprints

SHA-256 Fingerprint

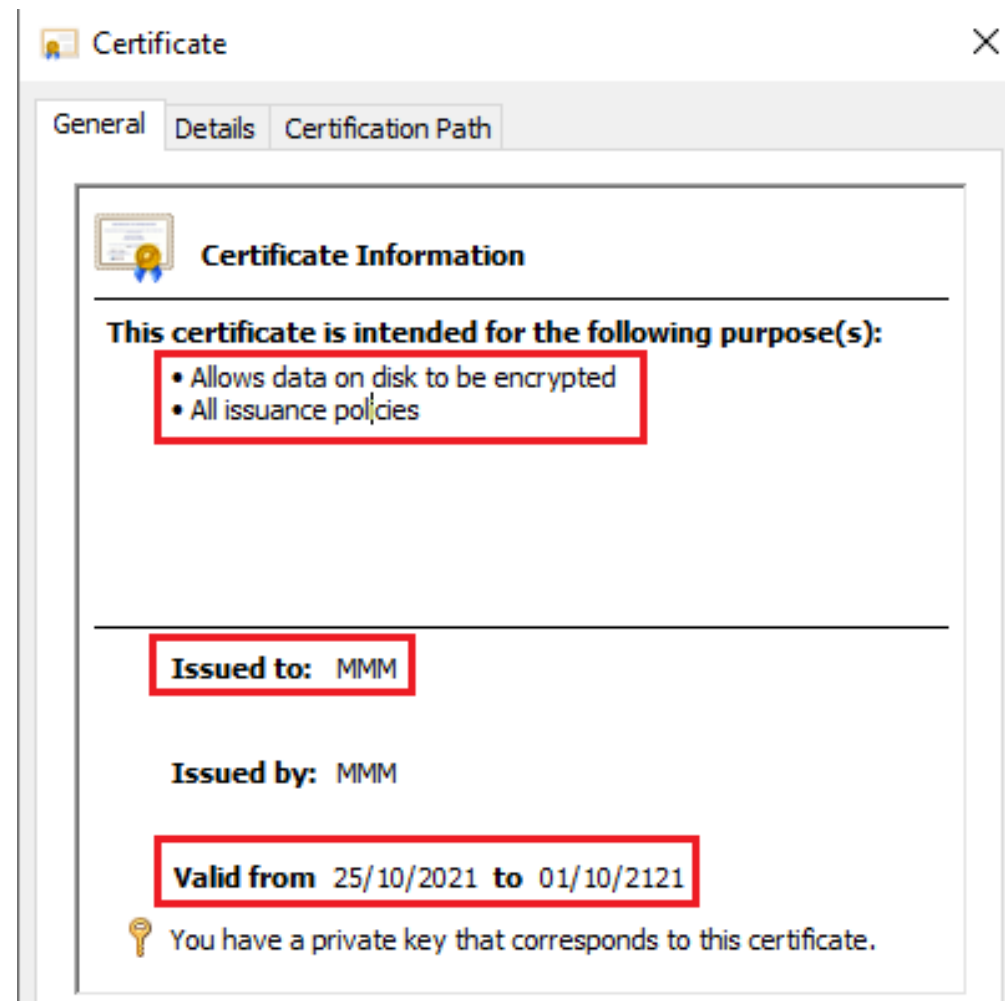
5E 6D 60 18 F1 A7 21 1D DC 4E E0 12 B5 70 AC EE
A0 E0 CD CE F7 1D 9D 51 42 CA 4D 1E 9D 81 AD 35
4A 71 2F 06 01 81 23 84 41 C8 8E 67 02 36 69 7B
09 15 D9 2B

SHA-1 Fingerprint

1.5. Chứng chỉ (Certificate)

Chứng chỉ máy khách (Client certificate):

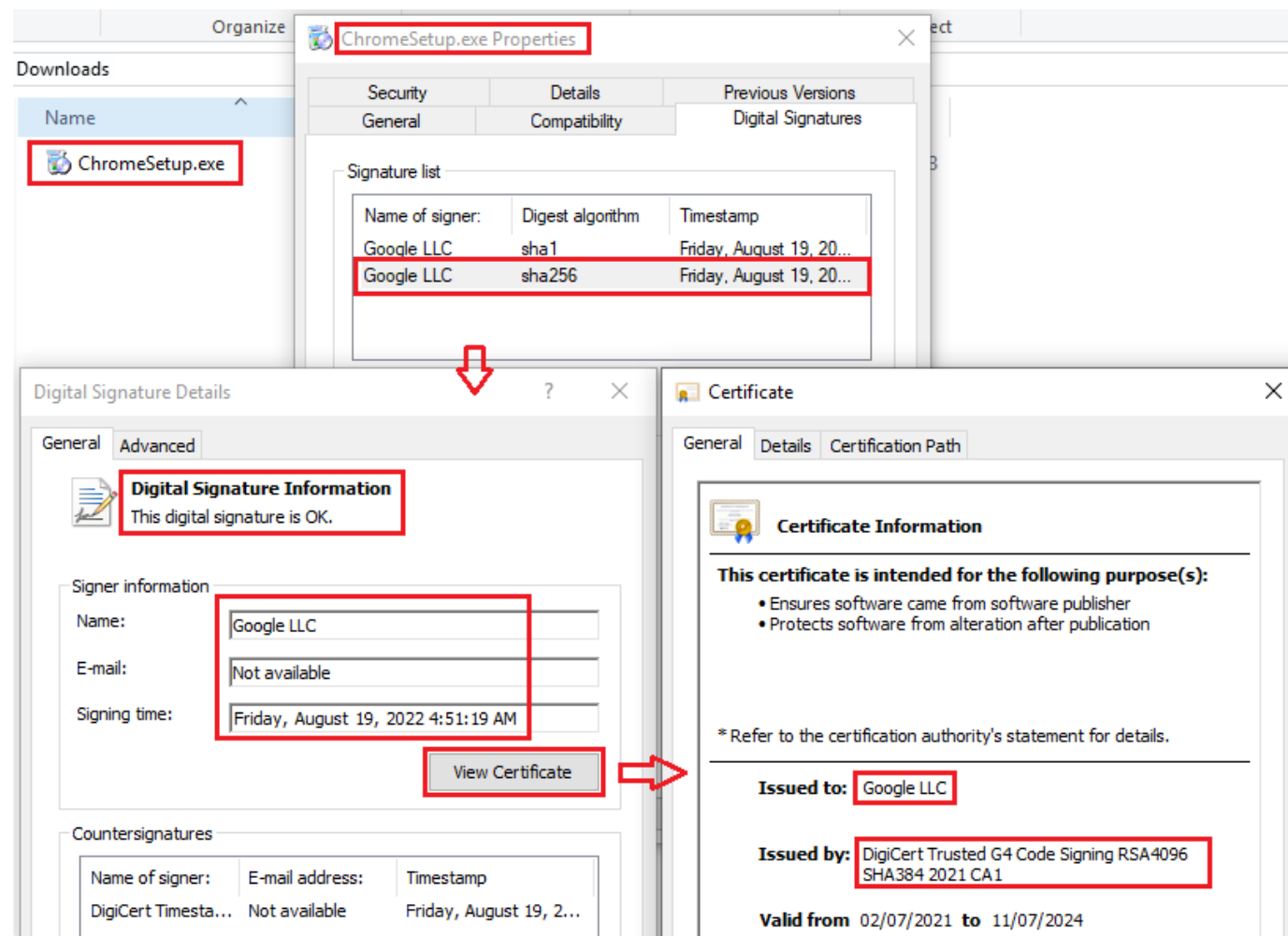
- Được sử dụng để xác định người dùng Internet, thiết bị, cổng kết nối..
- Là định danh kỹ thuật số xác nhận danh tính của khách hàng. Ví dụ, hai người dùng giao tiếp qua email sử dụng chứng chỉ máy khách để xác thực danh tính tương ứng của họ.
- Nhiều ứng dụng cho phép sử dụng chứng chỉ để xác thực người dùng truy cập tài nguyên cụ thể thay vì tên người dùng và mật khẩu.



1.5. Chứng chỉ

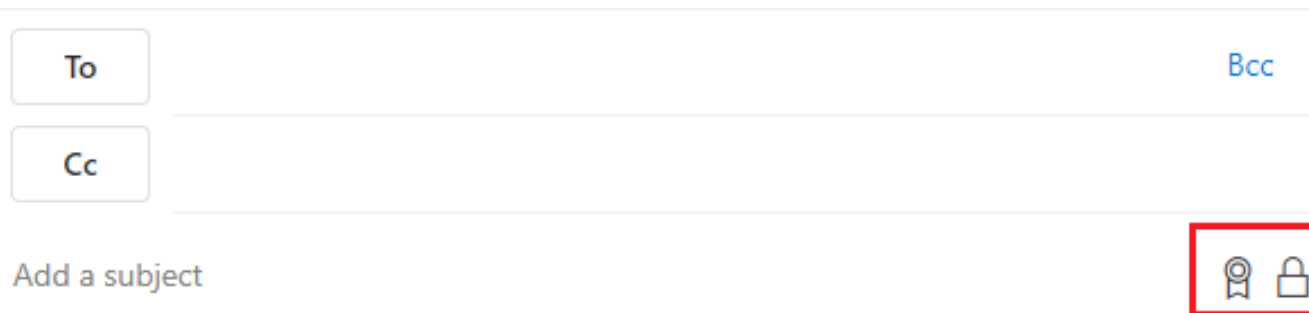
Chứng chỉ ký mã (code signing certificate):

- Chứa thông tin nhận dạng đầy đủ một thực thể và được cấp bởi tổ chức phát hành chứng chỉ, vd GlobalSign, được dùng để xác định phần mềm hoặc ứng dụng đến từ một nguồn cụ thể.
- Khi tải phần mềm, người dùng có thể có thể xem nguồn gốc source được hiển thị trong chứng chỉ ký mã, còn các nhà phát triển cũng có thể bảo vệ thương hiệu tránh giả mạo.



1.5. Chứng chỉ

- **Chứng chỉ email:** Người gửi cần xác định khóa công khai cụ thể để sử dụng cho người nhận tương ứng với giao thức S/MIME. Người gửi nhận được thông tin này từ chứng chỉ email. Thông thường, giao thức S/MIME được sử dụng khi giao tiếp email được triển khai trong tổ chức và với CA riêng của mình.



The image shows a portion of an email client's composition window. It includes input fields for 'To', 'Cc', and 'Bcc'. Below these fields is a label 'Add a subject'. At the bottom right of the composition area, there are two icons: a key icon and a lock icon, which are highlighted by a red rectangular box. These icons represent the S/MIME security options.

Message options

Sensitivity

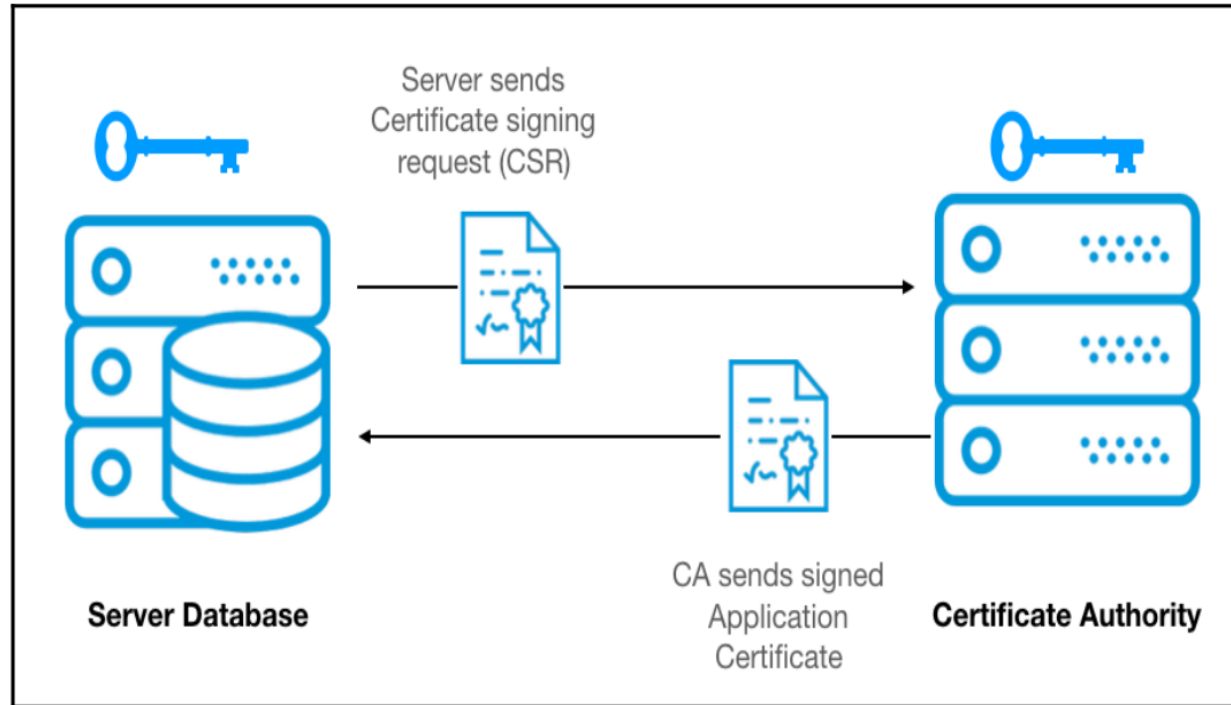
Normal

- ☐ Request a read receipt
- ☐ Request a delivery receipt
- ☒ Encrypt this message (S/MIME)
- ☒ Digitally sign this message (S/MIME)

OK Cancel

1.6. Tổ chức cấp chứng chỉ (CA)

- CA là một bên thứ ba đáng tin cậy xác nhận rằng người dùng, máy chủ, cơ sở dữ liệu và quản trị viên đúng với những đối tượng đó.
- CA kiểm tra thông tin đăng nhập của người dùng và cấp chứng chỉ, lưu ký nó bằng khóa bí mật.
- CA có thể là một giải pháp cục bộ hoặc nó có thể là một giải pháp được quản lý cung cấp dịch vụ chứng chỉ.



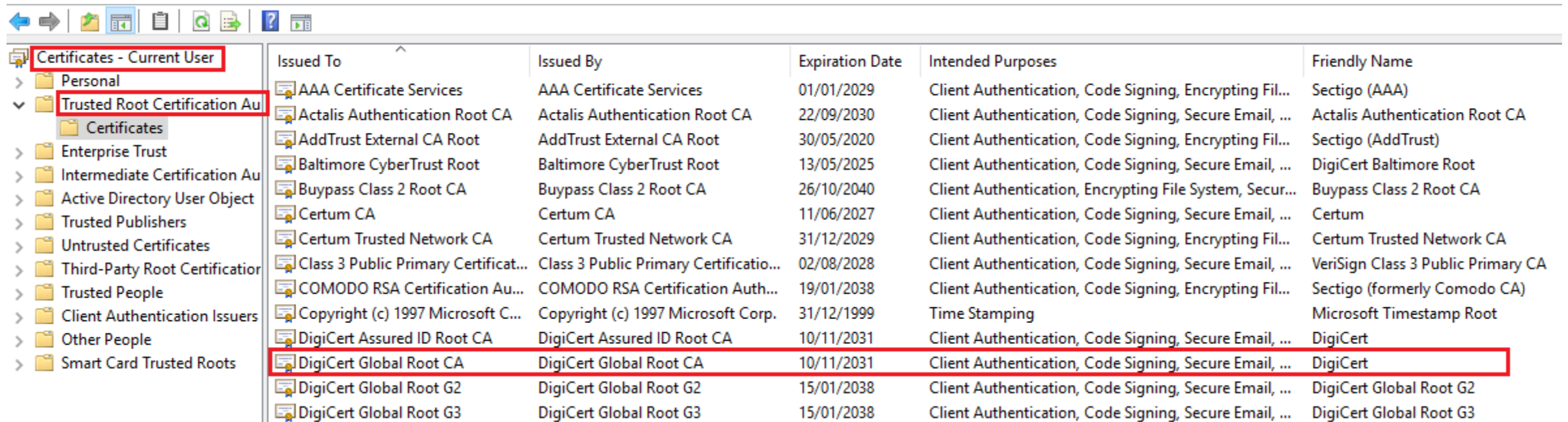
1.6. Tổ chức cấp chứng chỉ (CA)

Các chức năng của CA như sau:

- Cấp giấy chứng nhận
- Đưa chứng chỉ và danh sách thu hồi chứng chỉ (CRL) vào kho lưu trữ
- Quản lý yêu cầu thu hồi từ chủ sở hữu chứng chỉ

1.6. Tổ chức cấp chứng chỉ (CA)

Trong hình sau đây, chúng ta có thể thấy danh sách chữ ký số trong hệ thống máy khách từ một số CA với thông tin ngày hết hạn:



The screenshot shows the Windows Certificate Manager window. The left pane displays the 'Certificates - Current User' tree, with 'Trusted Root Certification Authorities' selected. The right pane shows a list of certificates. The 'DigiCert Global Root CA' is highlighted with a red box. The table below represents the data shown in the right pane.

Issued To	Issued By	Expiration Date	Intended Purposes	Friendly Name
AAA Certificate Services	AAA Certificate Services	01/01/2029	Client Authentication, Code Signing, Encrypting Fil...	Sectigo (AAA)
Actalis Authentication Root CA	Actalis Authentication Root CA	22/09/2030	Client Authentication, Code Signing, Secure Email, ...	Actalis Authentication Root CA
AddTrust External CA Root	AddTrust External CA Root	30/05/2020	Client Authentication, Code Signing, Encrypting Fil...	Sectigo (AddTrust)
Baltimore CyberTrust Root	Baltimore CyberTrust Root	13/05/2025	Client Authentication, Code Signing, Secure Email, ...	DigiCert Baltimore Root
Buypass Class 2 Root CA	Buypass Class 2 Root CA	26/10/2040	Client Authentication, Encrypting File System, Secur...	Buypass Class 2 Root CA
Certum CA	Certum CA	11/06/2027	Client Authentication, Code Signing, Secure Email, ...	Certum
Certum Trusted Network CA	Certum Trusted Network CA	31/12/2029	Client Authentication, Code Signing, Encrypting Fil...	Certum Trusted Network CA
Class 3 Public Primary Certificat...	Class 3 Public Primary Certificatio...	02/08/2028	Client Authentication, Code Signing, Secure Email, ...	VeriSign Class 3 Public Primary CA
COMODO RSA Certification Au...	COMODO RSA Certification Auth...	19/01/2038	Client Authentication, Code Signing, Encrypting Fil...	Sectigo (formerly Comodo CA)
Copyright (c) 1997 Microsoft C...	Copyright (c) 1997 Microsoft Corp.	31/12/1999	Time Stamping	Microsoft Timestamp Root
DigiCert Assured ID Root CA	DigiCert Assured ID Root CA	10/11/2031	Client Authentication, Code Signing, Secure Email, ...	DigiCert
DigiCert Global Root CA	DigiCert Global Root CA	10/11/2031	Client Authentication, Code Signing, Secure Email, ...	DigiCert
DigiCert Global Root G2	DigiCert Global Root G2	15/01/2038	Client Authentication, Code Signing, Secure Email, ...	DigiCert Global Root G2
DigiCert Global Root G3	DigiCert Global Root G3	15/01/2038	Client Authentication, Code Signing, Secure Email, ...	DigiCert Global Root G3

1.6. Tổ chức cấp chứng chỉ (CA)

Các loại CA:

- **Tổ chức cấp chứng chỉ số công cộng:** các nhà cung cấp chứng chỉ công cộng quản lý chứng chỉ được sử dụng cho mục đích thương mại và cá nhân. Thông tin đăng nhập chỉ được cấp sau khi thanh toán một khoản phí cụ thể.
- **Tổ chức cấp chứng chỉ số riêng:** Quản trị viên của tổ chức có thể cấp chứng chỉ cho hệ thống nội bộ và người dùng trong miền. Máy chủ Windows có thể tạo và lưu trữ các cặp khóa, nhưng các chứng chỉ riêng này sẽ không hợp lệ để liên lạc bên ngoài.

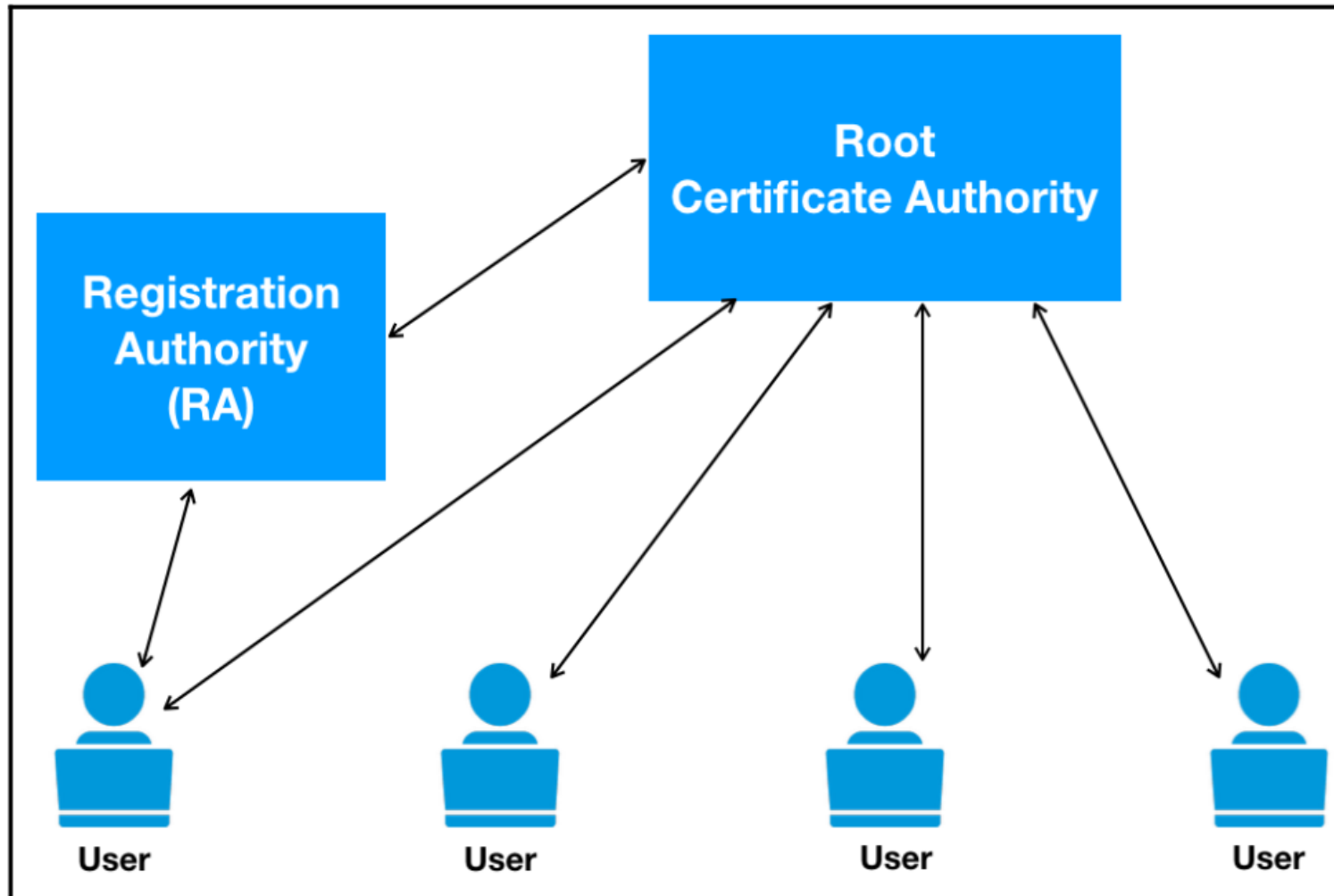
1.7. Tổ chức đăng ký (Registration Authority)

RA có trách nhiệm xác thực định danh của các thực thể mới hơn yêu cầu chứng chỉ từ tổ chức cấp chứng chỉ và duy trì thông tin dữ liệu đăng ký cục bộ và bắt đầu quá trình gia hạn và thu hồi chứng chỉ cũ.

Các chức năng của RA:

- Chịu trách nhiệm xác thực người dùng mới hoặc hệ thống yêu cầu chứng chỉ từ các CA:
- Thực hiện một số chức năng của CA.
- Hoạt động như một đại lý cho CA.
- Duy trì dữ liệu đăng ký cục bộ từ việc gia hạn và thu hồi chứng chỉ dự phòng.

1.7. Tổ chức đăng ký (RA)



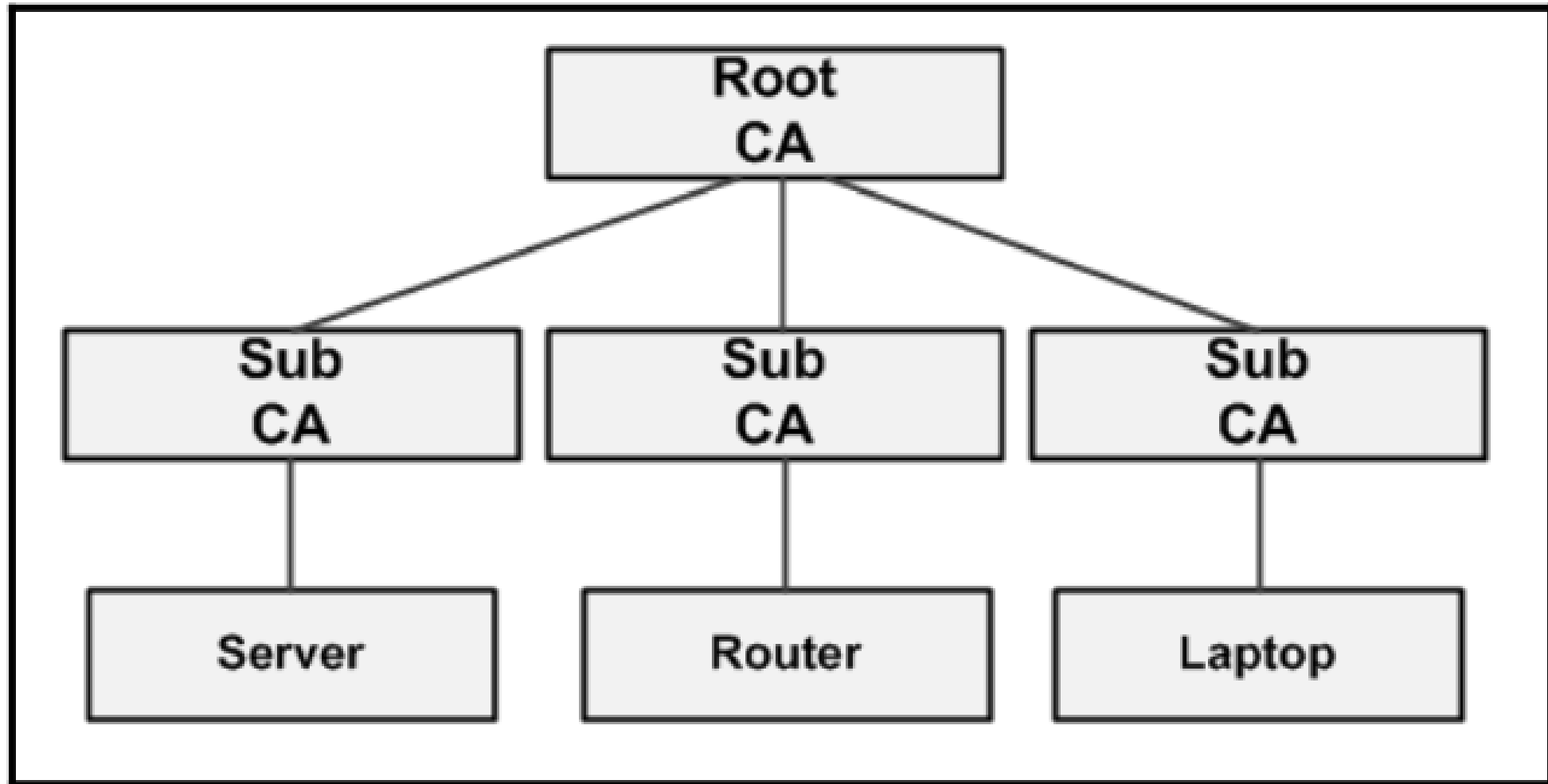
1.8. Kho chứng chỉ (Certificate Repository)

- CR là một cơ sở dữ liệu chứng chỉ có thể truy cập bởi tất cả các nút chọn một trong môi trường PKI, chứa thông tin liên quan đến thu hồi chứng chỉ và thông tin chính sách quản lý.
- Danh sách thu hồi chứng chỉ được sử dụng trong kho lưu trữ này để có được một danh sách cập nhật các chứng chỉ.
- Các chức năng của kho chứng chỉ như sau:
 - Nó cho phép truy xuất thông tin một cách không xác thực
 - Nó hoạt động như một cơ sở dữ liệu để giữ thông tin như chứng chỉ khóa công khai, danh sách thu hồi và chính sách

1.9. Kiến trúc

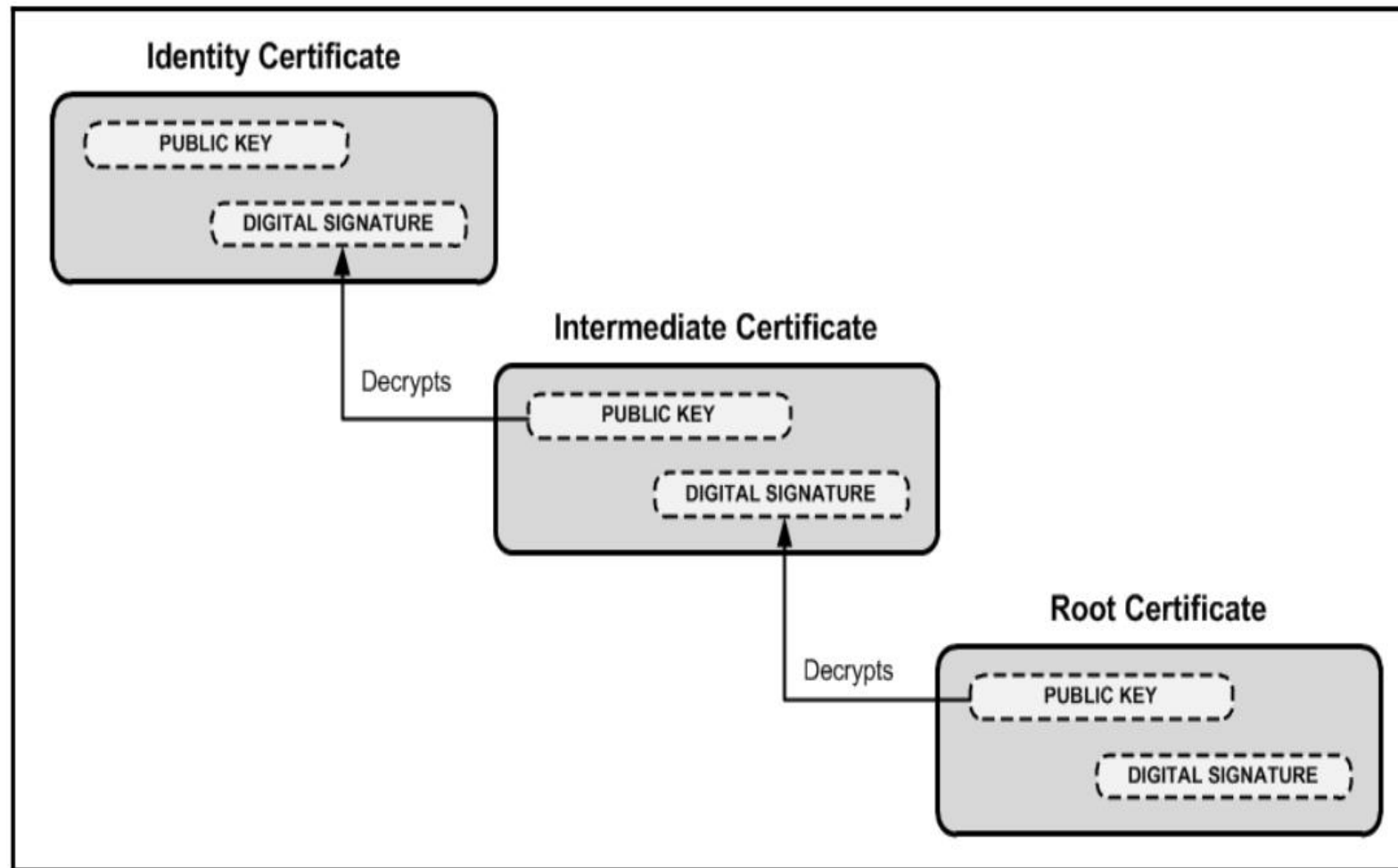
- Kiến trúc PKI hoạt động trên mô hình “**chuỗi sự tin cậy**” (chain of trust). Mô hình này nằm trong mối quan hệ tin tưởng giữa mỗi định danh.
- Sự khác biệt giữa một hệ thống phân cấp hai tầng và hệ thống phân cấp ba tầng là tầng thứ hai được đặt giữa CA gốc và CA phát hành.
- Lý do chính cho việc sử dụng một CA cấp hai là để sử dụng một CA chính sách chịu trách nhiệm cấp giấy chứng nhận cho CA phát hành.
- Hệ thống phân cấp CA ba tầng cung cấp bảo mật tốt hơn.
- Thiết kế CA cũng hữu ích nếu quản trị viên cần thu hồi các CA do bị chiếm dụng trái phép; việc thu hồi có thể được thực hiện ở cấp độ thứ hai, nhưng vẫn lưu lại các nhánh khác của gốc.

1.9. Kiến trúc



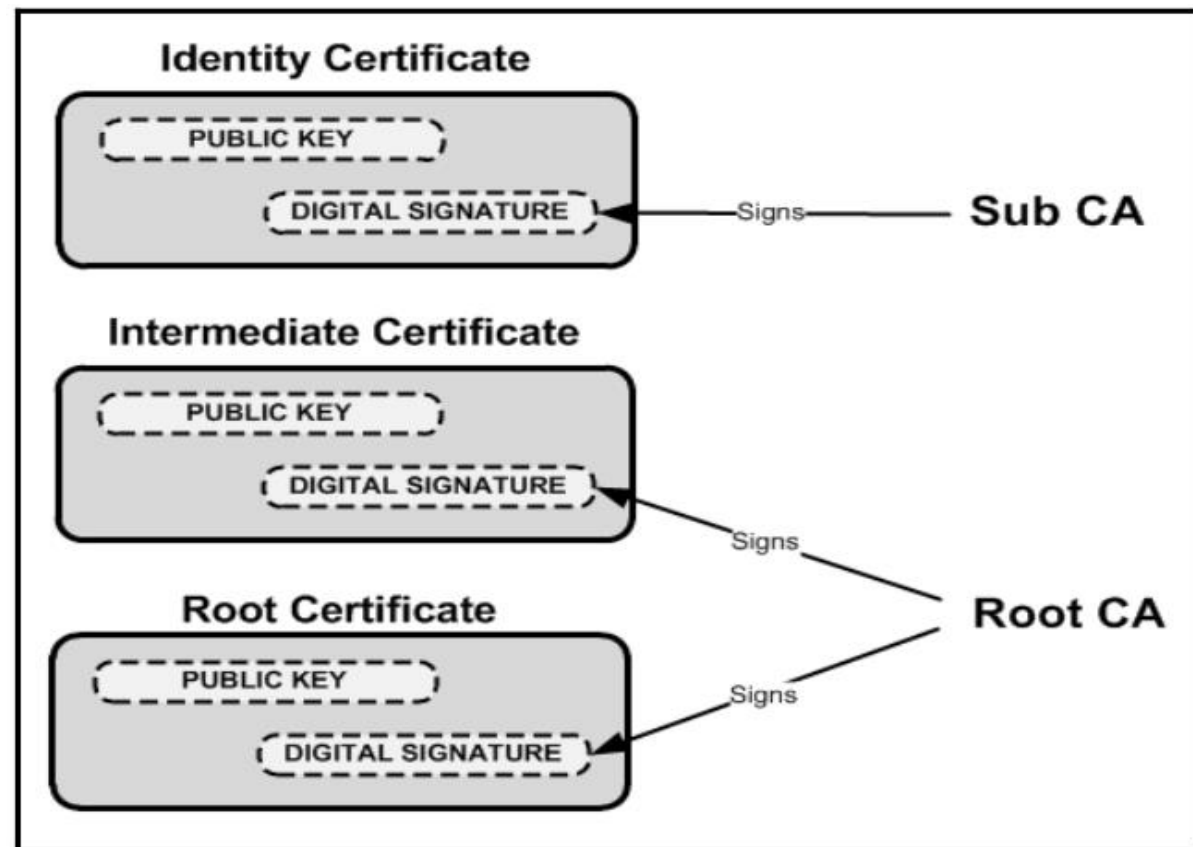
1.9. Kiến trúc

- Trong sơ đồ sau đây, chúng ta có thể thấy luồng chia sẻ và giải mã chứng chỉ số.
- Để xác thực các bên, chứng chỉ số được giải mã bằng cách sử dụng khóa công khai.



1.9. Kiến trúc

- Trong quá trình ký kết, CA gốc ký điện tử chứng chỉ trung gian bằng cách sử dụng khóa bí mật của nó.
- Quá trình này đạt được tính xác thực, có ý nghĩa là chứng chỉ trung gian được tin cậy bởi CA gốc.
- Mỗi CA có thể nhận được yêu cầu chứng chỉ từ máy khách và phát hành nó. Các máy khách không thể truy cập được CA gốc, nhưng máy khách có đủ điều kiện để giữ chứng chỉ CA gốc.
- Khách hàng gửi yêu cầu chứng chỉ cho CA cấp dưới và được cài đặt chứng chỉ



1.9. Kiến trúc

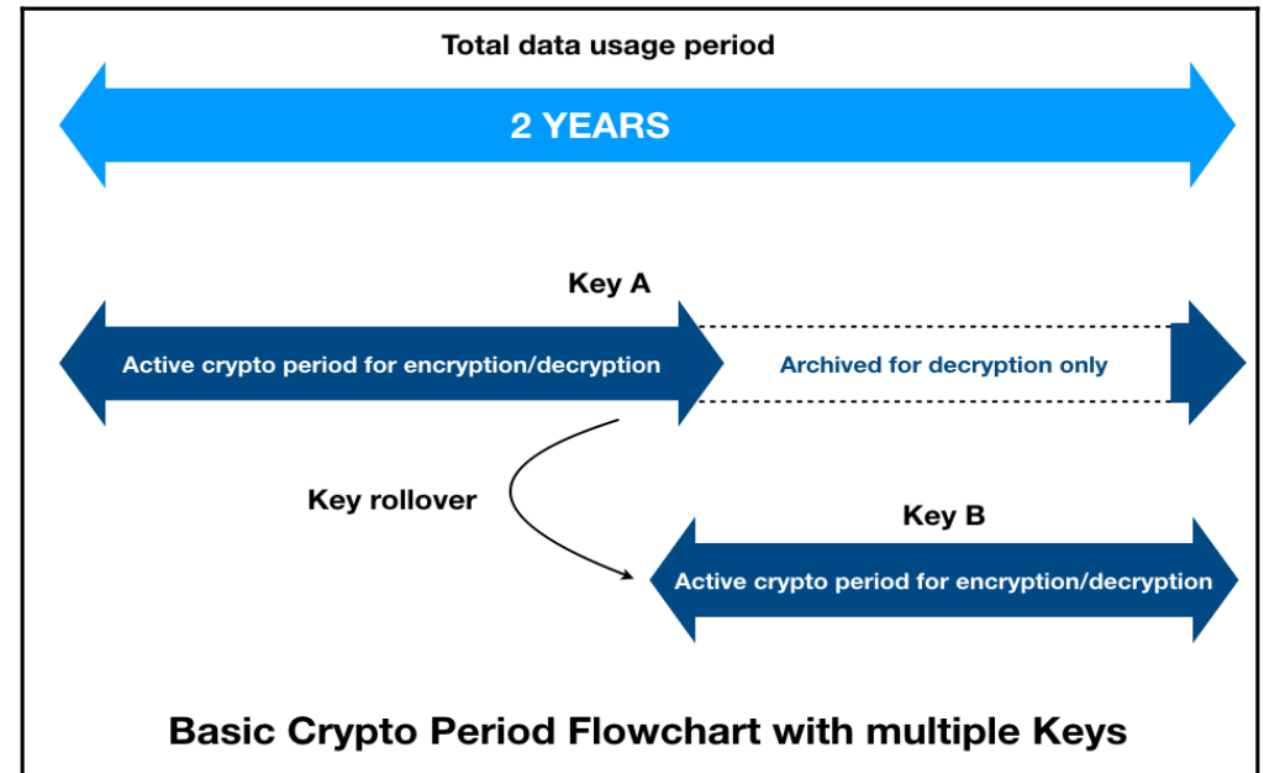
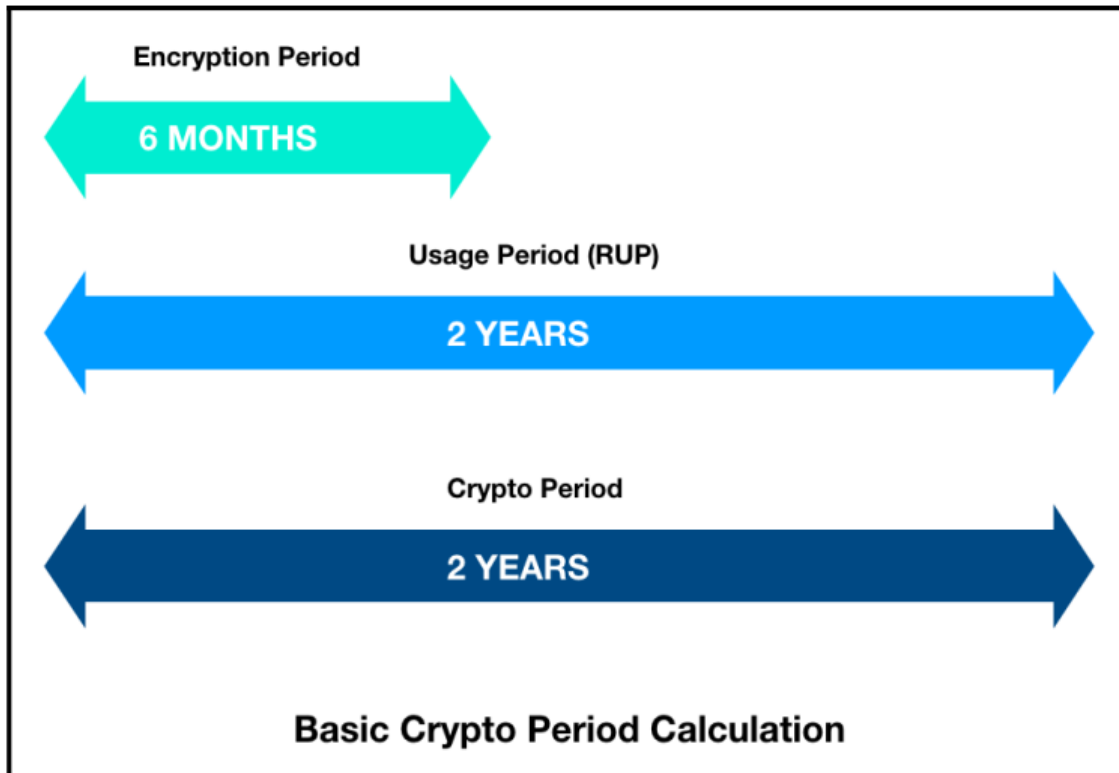
Trong ví dụ sau, một khách hàng yêu cầu truy cập trang web HTTPS. Trình duyệt của khách hàng được cài đặt sẵn với một số chứng chỉ CA gốc.

- B1. Máy khách kết nối với trang web SSL.
- B2. Trang web hồi đáp khách hàng với định danh và chứng chỉ trung gian của nó.
- B3. Khách hàng xác nhận định danh của chứng chỉ trung gian bằng cách giải mã chữ ký điện tử bằng cách sử dụng khóa công khai trung gian.
- B4. Khách hàng sau đó xác nhận rằng URL được yêu cầu phù hợp với tên phân biệt trong chứng chỉ định danh. Nếu không phù hợp, hệ thống sẽ hiển thị cảnh báo.
- B5. Lưu lượng sau đó được mã hóa / giải mã bởi máy khách bằng cách sử dụng một khóa công cộng và bởi các máy chủ bằng cách sử dụng một khóa bí mật.

1.10. Vòng đời chứng chỉ

- Theo Viện Tiêu chuẩn và Công nghệ Quốc gia (NIST), vòng đời khóa mã hóa là sự kết hợp của các giai đoạn trước khi hoạt động, vận hành, sau khi hoạt động và xóa các giai đoạn quản lý chính.
- Ta phải xem xét thời gian dành cho tài khoản vì tính hợp lệ của khóa luôn bị giới hạn.
- Thời gian mã hóa được sử dụng để ghi lại thời gian trong khi một khóa cụ thể được phép sử dụng.
- Thời gian mã hóa được xác định bằng cách kết hợp thời gian ước tính áp dụng việc mã hóa và giải mã.

1.10. Vòng đời chứng chỉ



1.10. Vòng đời chứng chỉ

- **Tạo khóa:**

- Khóa mã hóa được tạo và lưu trữ trên máy chủ quản lý khóa.
- Trình quản lý khóa tạo ra cặp khóa mã hóa thông qua quá trình mật mã hóa bằng cách sử dụng trình tạo bit ngẫu nhiên an toàn.
- Khi một cặp khóa được tạo ra, nó sẽ được lưu trữ với tất cả các thuộc tính trong cơ sở dữ liệu lưu trữ chính.
- Các thuộc tính thường bao gồm tên, kích thước, phiên bản, ngày kích hoạt, thu hồi, sao lưu, truy cập khóa và các thuộc tính liên quan khác.
- Trình quản lý khóa mã hóa theo dõi các phiên bản hiện nay và lịch sử của khóa

1.10. Vòng đời chứng chỉ

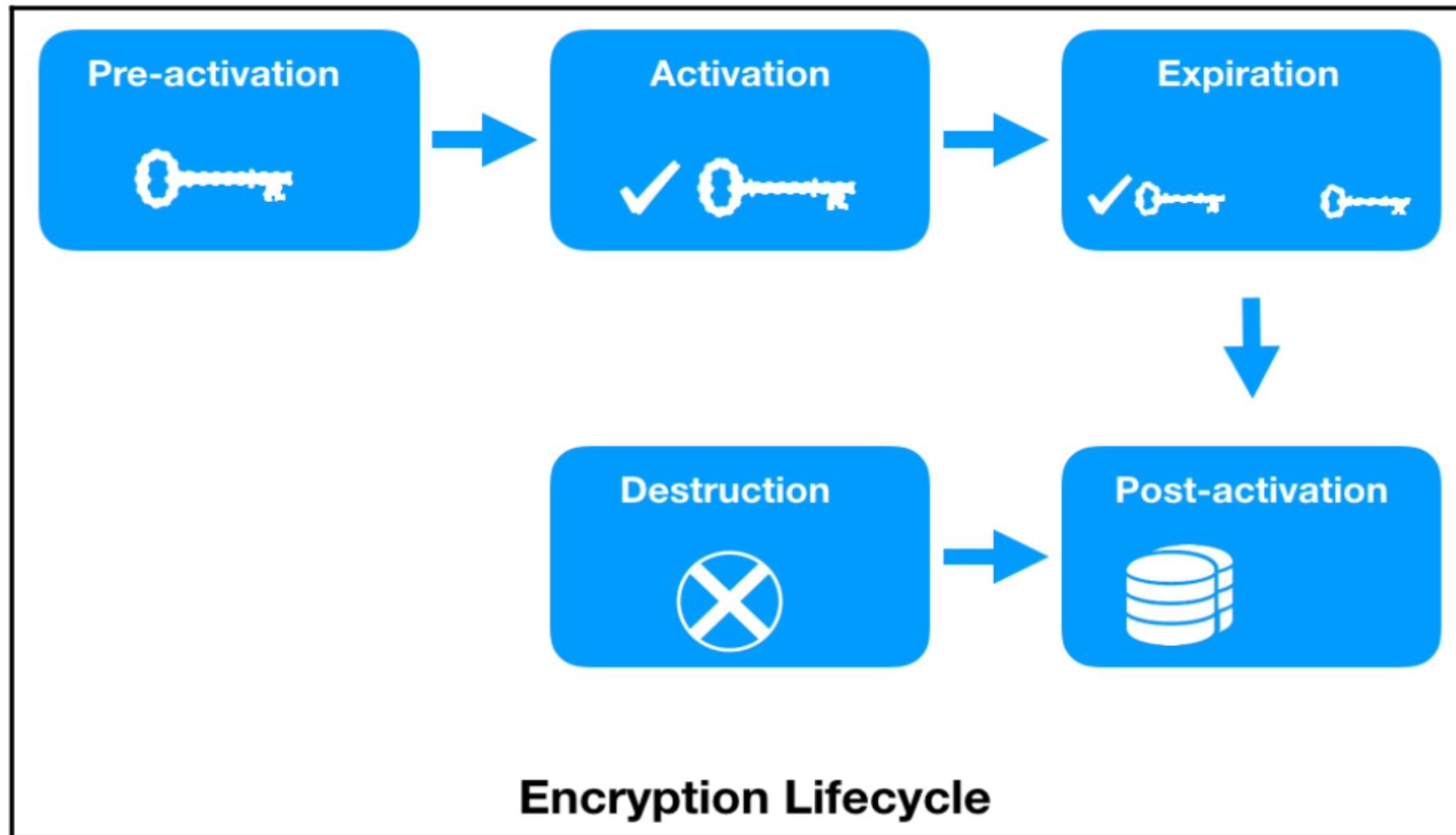
- **Sử dụng khóa và tái sử dụng:**

- Người quản lý khóa quản lý trạng thái của một khóa mã hóa trong suốt vòng đời của khóa, cho phép người dùng hoặc hệ thống truy xuất thông tin, mã hóa hoặc giải mã.
- Nếu tổ chức có chính sách sử dụng một cặp khóa mới mỗi năm cho các phòng ban, người quản lý nên giữ lại các khóa phiên bản trước và chỉ phân phối phiên bản hiện tại. Tuy nhiên, phiên bản trước vẫn có thể được lấy ra để thực hiện quá trình giải mã.

- **Thu hồi khóa:**

- Quản trị viên kết nối với người quản lý khóa để thu hồi khóa để nó không còn được sử dụng cho các quá trình mã hóa và giải mã. Quản trị viên thậm chí có thể kích hoạt lại khóa và sử dụng nó cho các bước tiếp theo khi cần.
- Người quản trị có thể sử dụng dữ liệu được giải mã đã được mã hóa trước đó, như bản sao lưu cũ.

1.10. Vòng đời chứng chỉ



1.10. Vòng đời chứng chỉ

- **Sao lưu (ký):**

- NIST đề xuất một kho lưu trữ cho tất cả các khóa bị hủy kích hoạt.
- Kho lưu trữ này phải được bảo vệ khỏi sự sửa đổi, xóa và thay đổi trái phép.
- Theo khuyến nghị, nên có một cơ chế khóa có thể phục hồi sau khi kết thúc mã hóa.

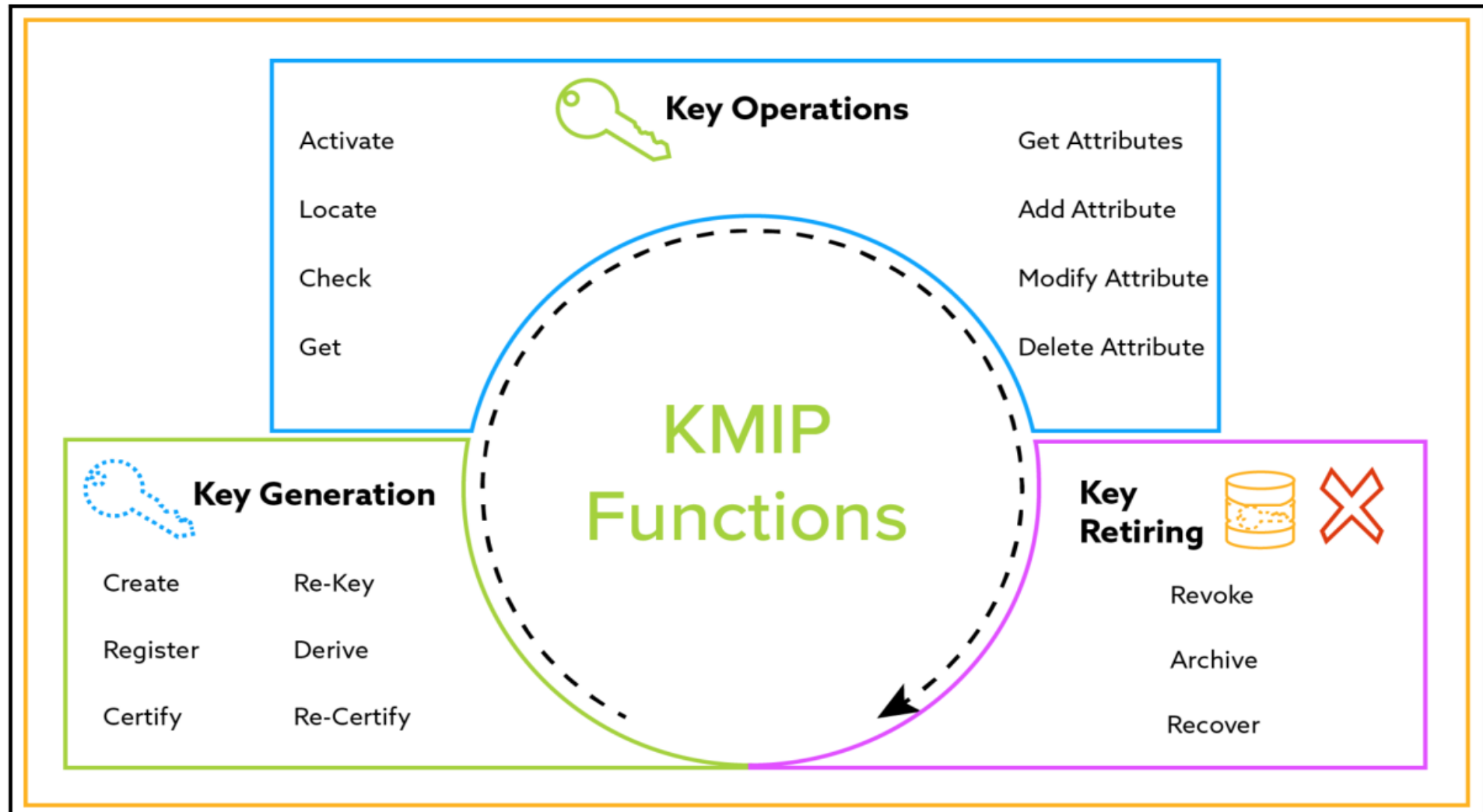
- **Xóa khóa (phá hủy):**

- Nếu khóa bị chiếm dụng hoặc không sử dụng trong một thời gian dài, quản trị viên nên chọn xóa khóa khỏi cơ sở dữ liệu lưu trữ khóa của trình quản lý khóa mã hóa.
- Người quản lý khóa sẽ xóa khóa và tất cả các phiên bản được liên kết hoặc có thể xóa một số phiên bản nhất định. Nếu khóa bị xóa, dữ liệu bị xâm nhập sẽ hoàn toàn an toàn và không thể khôi phục được vì không thể tạo lại khóa mã hóa.

1.11. Quản lý khóa

- Giao thức tương tác quản lý khóa (Key Management Interoperability Protocol - KMIP) được sử dụng để giao tiếp giữa khách hàng và máy chủ để thực hiện các hoạt động quản lý trên các đối tượng được lưu trữ.
- Giao thức này được phát triển để tạo điều kiện cho cả khóa mật mã đối xứng và không đối xứng, chứng chỉ kỹ thuật số và các mẫu liên quan khác để hợp lý hóa việc tạo và quản lý đối tượng.

1.11. Quản lý khóa



2. Những thách thức của mô hình PKI hiện có

- **Vấn đề 1 – nhu cầu bảo mật bổ sung:**

- Số lượng các DN triển khai các ứng dụng dựa trên cloud sử dụng PKI đang tăng rất nhanh.
- Nếu kho lưu trữ chứng chỉ trung tâm bị xâm nhập sẽ dẫn đến xâm nhập dữ liệu lớn và trộm cắp tài khoản.
- Các tổ chức có xu hướng sử dụng một lớp bảo mật bổ sung như mô-đun bảo mật phần cứng (Hardware security modules - HSM) để bảo mật các PKI của họ.
- Các HSM được triển khai để bảo vệ các PKI cho gốc quan trọng nhất và phát hành các khóa riêng CA.
- Xu hướng hiện nay là các tổ chức đang lựa chọn xác thực đa yếu tố cho quản trị viên và sử dụng HSM.

2. Những thách thức của mô hình PKI hiện có

- **Vấn đề 2 – tổ chức trung tâm:**

- Trên Internet, một tổ chức trung tâm (tổ chức gốc) chịu trách nhiệm quản lý các yêu cầu và phân giải DNS, chứng chỉ X.509... Tất cả các thiết bị và hệ thống kết nối Internet phải tin tưởng bên thứ ba để quản lý khóa công khai và mã định danh.
- Ngoài ra, các bên thứ ba đáng tin cậy này có rất nhiều khả năng ngăn chặn và xâm nhập đến tính toàn vẹn và bảo mật của người dùng trên toàn thế giới.
- Có một số trường hợp các bên thứ ba đáng tin cậy đã chia sẻ thông tin khách hàng cho các tổ chức bảo mật và các tổ chức khác. Họ có thể làm điều này vì lợi ích tài chính hoặc để phân tích hành vi của khách hàng.

3. Lợi ích của công nghệ Blockchain với hạ tầng PKI

- PKI có lỗ hổng lớn vì hệ thống quản lý tập trung của nó.
- Blockchain, về cơ bản là phân tán và cho phép giao tiếp giữa các bên mà không có bất kỳ sự tham gia của bên thứ ba nào.
- Cần một cách tiếp cận có hệ thống để triển khai mô hình PKI phân tán.

3.1. Cơ sở hạ tầng phân tán

- Blockchain là một mạng lưới phân tán mà không có sự tham gia của bên thứ ba.
- Cơ sở hạ tầng khóa công khai phân tán (DPKI) tạo ra các hệ thống xác thực trên các hệ thống công cộng mà không phụ thuộc vào bên thứ ba vì tiềm ẩn rủi ro bên thứ ba có thể làm tổn hại đến tính toàn vẹn và bảo mật của hệ thống.
- Blockchain được xây dựng với cách tiếp cận không tin cậy cho phép cả hai bên đáng tin cậy và không đáng tin cậy giao tiếp với nhau. Sự tin cậy được thiết lập giữa những người tham gia với các mô hình đồng thuận cho trạng thái của sổ cái.
- Theo định nghĩa, Blockchain cho phép lưu trữ bất kỳ loại giá trị nào với một số nút trong mạng. Với DPKI, giá trị này sẽ là một hình thức tài sản bí mật.

3.1. Cơ sở hạ tầng phân tán

- Chủ thể chính có thể được trao quyền kiểm soát trực tiếp đối với các mã định danh có thể đọc được trên toàn cầu, như tên miền trang web, bằng cách đăng ký mã định danh trong Blockchain.
- Chủ thể chính sử dụng mã định danh làm khóa tra cứu với cơ sở dữ liệu giá trị khóa.
- Blockchain cho phép gán các tài sản bí mật với khóa công khai và các thuộc tính khác. Các giá trị này có thể đọc được trên toàn cầu một cách an toàn, bằng cách cho phép khóa công khai liên kết chính xác với giá trị nhận dạng và việc xác thực được thực hiện bằng tra cứu mã định danh của khóa công khai mới nhất.
- Trong thiết kế của DPKI, hệ thống vẫn phân tán, và vẫn kiểm soát tốt mã định danh với chủ thể, giúp loại bỏ nguy cơ kho dữ liệu mã định danh bị xâm nhập.

3.2. Phương thức triển khai

- Trong Ethereum, PKI được thực thi như một chức năng trong một hợp đồng thông minh.
- Mỗi thực thể có thể có nhiều thuộc tính để xác thực quyền sở hữu. Thực thể này có thể là khóa công khai hoặc địa chỉ Ethereum.
- Mỗi giao dịch được xác định bằng cách sử dụng một khóa công khai và sau đó được đại diện bởi một thực thể ID tương ứng và PKI.
- Một hợp đồng thông minh được sử dụng để lập trình các sự kiện và chức năng của các hoạt động khác nhau trong PKI. Nó cũng có thể được cấu hình để gọi các hoạt động PKI cụ thể như tạo, trích xuất, gỡ bỏ, phá hủy...
- Các chức năng và quy trình này sẽ được viết bằng Solidity và được triển khai trong EVM, điều này sẽ cung cấp quản lý người dùng dễ dàng hơn cho các hoạt động PKI.

3.2. Phương thức triển khai

- **Đăng ký một thực thể:**
 - Người dùng hoặc hệ thống được thêm vào hệ thống PKI bằng cách gọi một sự kiện đăng ký từ hợp đồng thông minh.
 - Thực thể có thể đơn giản chỉ là địa chỉ Ethereum, khóa công khai, ID thuộc tính, dữ liệu và băm dữ liệu.
 - Sự kiện được cấu hình trên hợp đồng thông minh thu thập thực thể và chuyển tiếp nó như một giao dịch đến Ethereum.
 - Các giao dịch trong hàng đợi được khai thác, một khối được tạo ra và sau đó sẽ được thêm vào Blockchain.

3.2. Phương thức triển khai

- **Ký các thuộc tính:**
 - Một thực thể có thể được đặc trưng bằng cách sử dụng một sự kiện đăng ký.
 - Mỗi thuộc tính của thực thể có thể được ký bởi hệ thống PKI thông qua một hợp đồng thông minh và một giao dịch sẽ được phát hành.
 - Thực thể đã lưu ký này sau đó sẽ được cung cấp cho các thực thể hoặc người dùng khác.
- **Truy xuất các thuộc tính:** thuộc tính của các thực thể có thể được định vị bằng cách áp dụng một bộ lọc cho Blockchain bằng cách sử dụng ID tương ứng của các sự kiện đã được cấu hình trên hợp đồng thông minh.

3.2. Phương thức triển khai

- **Thu hồi chữ ký:**

- Là một trong những chức năng quan trọng nhất theo yêu cầu của bất kỳ giải pháp PKI nào: thu hồi chữ ký điện tử trên các thuộc tính hoặc thực thể.
- Việc thu hồi trở nên cực kỳ quan trọng khi người dùng mất khóa của mình hoặc nó bị xâm nhập.
- Hợp đồng thông minh có thể được cấu hình để gọi sự kiện thu hồi và thu hồi chữ ký trên một thực thể cụ thể.

3.3. Các yêu cầu

Trong việc triển khai DPKI, tổ chức đăng ký vẫn có một vai trò trong cơ sở hạ tầng, nhưng bị hạn chế để đảm bảo rằng định danh của các thực thể được đại diện trong mạng:

- Cần đảm bảo phần mềm luôn dưới sự kiểm soát của các chủ thể chính và các khóa tương ứng.
- Khóa riêng phải được tạo ra theo cơ chế phân tán để đảm bảo chúng vẫn nằm dưới sự kiểm soát của chủ thể chính và nghiêm cấm việc tạo ra một cặp khóa đại diện cho một chủ thể chính.
- Không thực thể nào có thể thay đổi các thực thể khác mà không có sự đồng ý của chủ thể chính.
- Một khi một không gian tên được tạo ra trong một Blockchain thông qua một hợp đồng thông minh Ethereum, nó không thể bị phá hủy.
- Việc đăng ký và gia hạn số nhận dạng phải minh bạch.
- Theo mặc định, phần mềm quản lý mã định danh phải đảm bảo rằng tất cả các hoạt động như tạo, cập nhật, gia hạn hoặc xóa mã định danh được chuyển tiếp thông qua cơ chế phân tán.

4. Kết luận

- Trong chương này, bạn đã học được về tầm quan trọng của PKI và cách PKI giải quyết các yếu tố tin cậy giữa người dùng kết nối Internet.
- Chúng ta cũng hiểu một số thành phần trong PKI chịu trách nhiệm làm cho PKI trở thành một mô hình đáng tin cậy hơn để giữ sự tin cậy trên mạng công cộng.

